

MISE EN ŒUVRE

DU CADRE DE GOUVERNANCE DES DONNEES ET DE L'IA

STRATEGIE DE GOUVERNANCE DES DONNEES



Rapport de diagnostic	
Version	1.0
Client	Etude de cas - SPOTIFY
Date de la version	30/09/2026
Description de la version	Bloc 1 - certification RNCP41993
Modules concernés	Livrable 3
Auteur	Ronan GUILLOU

Table des matières

1	Contexte	3
2	Modèle organisationnel	3
2.1	Pourquoi ce choix ?	3
2.2	Fonctionnement du CoE	3
3	Technologies et outils	3
4	Implémentation du pilote	4
4.1	Objectif et périmètre	4
4.2	Équipe pilote	4
4.3	Calendrier.....	4
4.4	Livrables	5
4.5	Indicateurs clés	5
5	Risques et conduite du changement	6
5.1	Risques.....	6
5.2	Formation et accessibilité	6
6	Déploiement et amélioration continue.....	7
6.1	Dispositif d'audit	7
6.2	Amélioration continue et veille	7

1 Contexte

Cette troisième étape transforme le cadre de gouvernance des données et de l'IA, défini lors des étapes précédentes, en un **plan d'exécution** concret pour Spotify. Dans un contexte où des données cloisonnées, une exposition au RGPD et au CCPA et un moteur de recommandation créent des risques de qualité, de conformité et de biais, il s'agit de décider comment organiser la gouvernance, avec quels outils l'équiper, et sur quel périmètre la tester avant de la généraliser.

Le plan retient un modèle de **Center of Excellence** et une pile d'outils couvrant catalogue, qualité, traçabilité, registre de modèles et contrôle des accès. Nous faisons le choix d'un pilote orienté IA, il porte sur les données d'entraînement du système de recommandation, pendant 6 mois. Ce périmètre permet de tester sur un cas réel les risques et de vérifier que la gouvernance de l'IA repose bien sur celle des données. Ce plan prépare un déploiement progressif mesuré par des KPI et des audits.

2 Modèle organisationnel

2.1 Pourquoi ce choix ?

Nous retenons le **Center of Excellence (CeO)** : des règles communes fixées au centre, appliquées par des relais dans chaque département. C'est la recommandation de *l'Executive Q&A Guide* pour une entreprise aussi grande et diverse que Spotify.

Les deux autres modèles ont chacun un défaut majeur. Le modèle centralisé crée un goulot d'étranglement et laisse le métier se désintéresser de la donnée. Le modèle embarqué produit des standards incohérents et non alignés et maintient les silos. Le CoE corrige ces deux défauts :

- **Des silos à résorber.** Le business case décrit des départements qui gèrent leurs données chacun de leur côté. Des standards communs fixés au centre répondent directement à ce problème.
- **Une échelle mondiale.** Avec plus de 180 pays, des relais locaux absorbent les besoins des métiers sans saturer l'équipe centrale.
- **Un métier qui s'approprie la donnée.** Les Data Owners et Data Stewards, placés dans les départements, portent la responsabilité au lieu de la laisser à une fonction support.
- **Une conformité cohérente.** Le RGPD, le CCPA et l'AI Act ont des exigences différentes. Un cadre commun garantit qu'elles sont appliquées de la même façon dans tous les départements.
- **Une expertise IA mutualisée.** L'équipe centrale apporte les compétences (traçabilité des données d'entraînement, biais, conformité) que les équipes de recommandation ne peuvent pas développer seules.
- **Un coût acceptable.** Le CoE ajoute une couche de coordination et convient mal aux petites structures, mais Spotify a la taille et la maturité pour la supporter.

2.2 Fonctionnement du CoE

Une équipe centrale, sous l'autorité du **Chief Data Officer** et du **Data Governance Committee**, définit les politiques, les standards de qualité et le catalogue. Dans chaque domaine (écoute et recommandation, contenu, marketing), un **Data Owner** est responsable des données côté métier et un **Data Steward** veille à leur qualité au quotidien. Le **DPO** suit la conformité RGPD et CCPA, et l'équipe plateforme assure la sécurité technique.

Pour l'IA, deux rôles s'ajoutent à ceux de l'étape 2 : un **Model Owner**, responsable des données d'entraînement et des biais d'un modèle, et un référent **conformité AI Act**. Le comité se réunit chaque mois pendant la phase pilote, puis chaque trimestre. Les problèmes remontent du Data Steward au Data Owner, puis au comité, et le DPO comme le référent IA peut alerter directement le comité.

3 Technologies et outils

Les outils donnent aux rôles du CoE les moyens d'appliquer la gouvernance au quotidien : documenter, contrôler la qualité, protéger, tracer et prouver la conformité. Nous les classons par domaine du DMBOK et partons des outils recommandés par le *Tech Tools Overview*, que nous complétons par des standards du marché, en particulier pour la traçabilité et la gouvernance de l'IA.

Chaque choix sera validé par une courte PoC, notamment sur l'intégration avec le data lake et le cloud existant de Spotify.

Domaine	Rôle	Outils
Gouvernance des données (et conformité)	Gérer les consentements, les demandes d'accès et de suppression, les analyses d'impact, et produire les rapports pour le DPO	OneTrust, TrustArc, VeraSafe + Microsoft Purview
Métadonnées	Documenter chaque jeu de données (propriétaire, sensibilité, définition) et en faire l'outil de travail des Data Stewards	Collibra, Alation, Apache Atlas + DataHub (IA), OpenMetadata
Qualité des données	Profiler les données, appliquer les règles de qualité et alerter le Data Steward en cas d'anomalie	Ataccama ONE, Informatica DQ, Talend + GX Core, Soda (IA)
Sécurité des données	Contrôler qui accède à quoi (RBAC, ABAC), chiffrer, pseudonymiser et journaliser les accès	Splunk, DataGuard, Vormetric + Apache Ranger, Okta (IA)
Intégration et interopérabilité	Suivre le trajet des données (lineage) de la source jusqu'au modèle, et orchestrer les pipelines	OpenLineage, Apache Airflow, + dbt, OpenMetadata
Extension IA		
Gouvernance de l'IA	Relier chaque modèle à ses données d'entraînement, mesurer les biais et la dérive, tracer les approbations	MLflow, Evidently

Les autres domaines (architecture, modélisation, stockage et opérations, entrepôt et BI, documents, données de référence) ne sont pas détaillés ici car ils reposent sur la plateforme de données existante de Spotify et ne sont pas mentionnés dans le document.

4 Implémentation du pilote

4.1 Objectif et périmètre

Le pilote teste le cadre de gouvernance sur un cas réel d'IA avant de le généraliser. Il porte sur les données qui entraînent un modèle de recommandation (par exemple les playlists personnalisées) : données d'écoute des utilisateurs et métadonnées de contenu.

Un modèle ne peut être fiable que si ses données le sont : elles doivent donc être validées avant d'entrer dans l'IA, c'est-à-dire cataloguées, de qualité contrôlée, licites et tracées. Le pilote applique cet ordre : la gouvernance des données précède celle du modèle. Il concentre aussi les risques liés à l'IA : données personnelles, biais, traçabilité des jeux de données et exigences de l'AI Act.

4.2 Équipe pilote

Le pilote mobilise une équipe restreinte qui réunit les rôles du CoE concernés par les données de recommandation, afin que chaque décision (finalité, qualité, conformité, modèle) ait un responsable identifié, selon la matrice RACI de l'étape 2.

- **Chef de projet du pilote** : coordonne et rend compte au comité.
- **Data Owner** : décide des finalités et des accès.
- **Data Steward** : gère la qualité et la documentation du catalogue.
- **Model Owner** : responsable des données d'entraînement, de la performance et des biais.
- **DPO et référent conformité IA** : audit RGPD, analyse d'impact, classification AI Act.
- **Data Engineer** : installe les outils et applique les contrôles d'accès.
- **Analyste** : crée, valide et déploie les tableaux de bord KPI.

4.3 Calendrier

Le pilote dure 6 mois, dans la fourchette de 3 à 6 mois de l'*Executive Q&A Guide*. Chaque étape a un responsable et un point de vérité, c'est-à-dire une preuve validée par une personne distincte du responsable, qui confirme le résultat.

Mois	Activités	Responsable	Résultat	Point de vérité
Mois 1	Lancement, évaluation de maturité, inventaire des jeux de données, analyse des risques	Chef de projet Data Owner	Périmètre validé et risques priorisés	Périmètre et risques validés par le comité de gouvernance
Mois 2	Catalogage et classification de sensibilité, traçabilité de la source au modèle	Data Steward Data Engineer	Jeux de données catalogués avec lineage	Contrôle par échantillon du lineage et de la classification par le Data Owner

Mois 3	Règles de qualité, tableaux de bord KPI, revue de mi-parcours	Data Steward Analyste	Qualité mesurée, plan ajusté si besoin	Rapport de qualité comparé à la situation du mois 1, relu par le Data Owner
Mois 4	Droits d'accès (RBAC/ABAC), pseudonymisation, audit RGPD	Data Engineer DPO	Données conformes et accès maîtrisés	Rapport d'audit du DPO et revue des droits d'accès
Mois 5	Registre de modèles, tests de biais, documentation AI Act	Model Owner Référent IA	Modèle tracé et documenté	Fiche de modèle approuvée par le référent conformité IA
Mois 6	Mesure des KPI, bilan, retours des parties prenantes, plan de déploiement	Chef de projet Analyste	Décision de généralisation	KPI mesurés face aux cibles, présentés au comité qui décide

Une réunion de suivi, a lieu chaque mois. Le chef de projet y présente l'avancement et les blocages, confirme le point de vérité de l'étape qui vient de s'achever et soumet les risques au Data Governance Committee. Le comité décide alors du passage à la phase suivante ou de son report, et ajuste le planning si nécessaire.

4.4 Livrables

Les livrables reprennent ceux du *Pilot Template*, avec un ajout propre à l'IA. Chacun est validé à son point de vérité du calendrier.

Livable	Contenu	Mois	Validé par
Rapport de risques	Risques identifiés (sécurité, biais, confidentialité) et mesures de traitement, mis à jour au bilan	1 et 6	Comité de gouvernance
Plan d'intégration technique	Comment les données sont cataloguées, tracées et rendues accessibles	2	Data Owner
Rapport de qualité des données	Améliorations mesurées par rapport à la situation du mois 1	3	Data Owner
Tableau de bord KPI	Suivi mensuel des indicateurs, tenu par l'Analyste	3 à 6	Chef de projet
Évaluation de conformité	Résultat de l'audit RGPD et CCPA et de l'analyse d'impact	4	DPO
Fiche de modèle IA	Données d'entraînement, tests de biais et niveau de risque AI Act	5	Référent conformité IA
Retours des parties prenantes	Avis des utilisateurs et des équipes sur le cadre de gouvernance	6	Comité de gouvernance

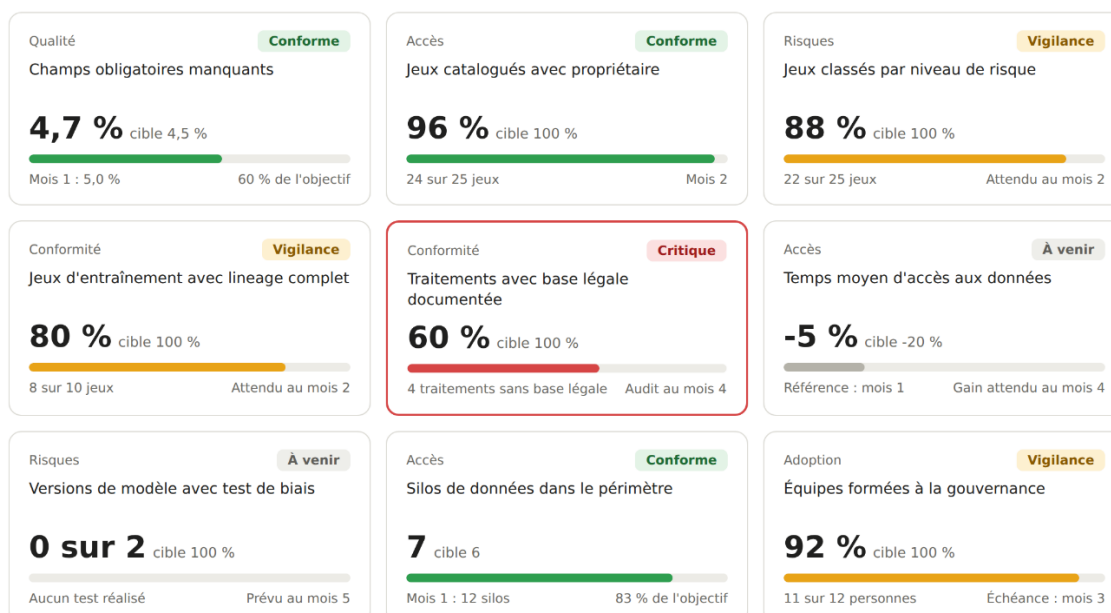
4.5 Indicateurs clés

Les KPI mesurent si le pilote atteint ses quatre buts (**qualité, conformité, accès, réduction des risques**) et fondent la décision de généralisation au mois 6. Ils sont suivis chaque mois dans le tableau de bord, puis présentés au comité à la réunion de suivi.

Pilote gouvernance IA, mois 3 sur 6 (revue de mi-parcours)

Tableau de bord KPI, données d'exemple

3 conformes 3 en vigilance 1 critique 2 à venir



Indicateur	But	Cible
Complétude des champs obligatoires (part de champs renseignés)	Qualité	Taux de champs manquants réduit de 10 % par rapport au mois 1
Jeux de données catalogués, avec propriétaire	Accès	100 % des jeux du pilote
Jeux de données classés par niveau de risque (sensibilité, données personnelles, risque de biais)	Risques	100 % des jeux du pilote, avec les contrôles d'accès associés
Jeux d'entraînement avec lineage complet jusqu'au modèle	Conformité	100 % des jeux du pilote
Traitements avec base légale ou consentement documenté	Conformité	100 % des traitements du pilote
Temps moyen d'accès aux données pour les utilisateurs autorisés	Accès	Baisse de 20 % par rapport à la mesure du mois 1
Versions de modèle avec un test de biais documenté	Risques	100 % des versions produites pendant le pilote
Nombre de silos de données dans le périmètre	Accès	Recensement au mois 1, puis réduction de moitié au mois 6
Membres de l'équipe pilote formés à la gouvernance	Formation	100 % formés avant le mois 3, avec un retour de satisfaction collecté

5 Risques et conduite du changement

5.1 Risques

Le pilote est exposé à **7 risques** principaux, de la conformité RGPD aux biais des modèles. Chacun a une mesure de traitement et un responsable, et leur suivi est inscrit à l'ordre du jour de la réunion mensuelle. Un KPI de conformité critique remonte immédiatement au DPO et au comité.

Risque	Probabilité	Impact	Mesure	Responsable
Non-conformité RGPD et CCPA	Moyenne	Élevé	Audit au mois 4, base légale documentée pour chaque traitement	DPO
Résistance au changement	Élevée	Moyen	Ateliers, retours recueillis dès le début, Data Stewards comme relais	Chef de projet
Qualité des données non résolue	Faible	Élevé	Règles et alertes automatiques, revue mensuelle des indicateurs	Data Steward
Échec d'intégration technique	Moyenne	Élevé	Équipe plateforme associée dès le mois 1, preuve de concept des outils	Data Engineer
Biais ou données d'entraînement non licites	Moyenne	Élevé	Classification des risques, tests de biais, fiche de modèle	Model Owner
Retard du calendrier ou validateur indisponible	Moyenne	Moyen	Point d'étape mensuel, report décidé par le comité	Chef de projet
Accès non autorisé ou fuite de données	Moyenne	Élevé	RBAC/ABAC dès le mois 4, pseudonymisation des données d'écoute, chiffrement, journal des accès, procédure de notification des violations sous 72 h	Data Engineer, avec le DPO

5.2 Formation et accessibilité

Une gouvernance que personne ne comprend reste sur le papier : c'est la formation qui transforme des rôles, des règles et des outils en gestes quotidiens, et qui réduit ainsi les risques de non-conformité, de mauvaise qualité et de biais.

Toutes les personnes du périmètre doivent être formées avant le mois 3, selon leur rôle. C'est la cible du KPI d'adoption, et c'est la mesure principale contre le risque de résistance au changement.

Public	Contenu
Data Owners et Data Stewards	Règles de gouvernance, utilisation du catalogue

Équipes data et IA	Qualité, détection des biais, exigences de l'AI Act
Autres équipes du périmètre	Sensibilisation au RGPD et au CCPA

La documentation, des tutoriels et un helpdesk prolongent la formation, et un questionnaire de satisfaction recueille les retours chaque mois (on pourrait ajouter un KPI).

Accessibilité et inclusion. La formation doit être accessible à tous, y compris aux personnes sans profil technique : le support de cours recommande une documentation et des formations à tous les niveaux. Les supports sont rédigés en langage simple et les sessions sont proposées en plusieurs langues et à plusieurs horaires, compte tenu de la présence mondiale de Spotify.

6 Déploiement et amélioration continue

Si le bilan du mois 6 est positif, le cadre est étendu aux autres données (produit, marketing), puis aux autres départements et régions, sur 12 à 18 mois, comme le prévoit l'*Executive Q&A Guide*. Chaque extension reprend la méthode du pilote et ne démarre qu'après la décision du comité.

6.1 Dispositif d'audit

Le cadre est contrôlé par des audits : un suivi mensuel des KPI, un audit de conformité du DPO au mois 4, et un audit indépendant au mois 6, par une équipe étrangère au pilote, avant la décision de généralisation.

Niveau	Qui	Quand	Objet
Contrôle continu	Data Stewards et Analyste	Chaque mois	Suivi des KPI et points de vérité
Audit de conformité	DPO et référent IA	Mois 4 et 5, puis chaque année	RGPD, CCPA, AI Act, fiche de modèle
Audit indépendant	Audit interne étranger au pilote ou prestataire externe	Mois 6, puis chaque année	Ensemble du cadre, avant la décision de généralisation

L'audit indépendant rend compte au Data Governance Committee. Il garantit que les équipes du pilote ne sont pas seules à juger leur propre travail.

6.2 Amélioration continue et veille

Les constats d'audit, les retours des parties prenantes et les KPI alimentent chaque trimestre une revue de la politique de gouvernance par le comité : ajustement des politiques, des cibles et des outils si besoin. Le DPO et le référent conformité IA assurent la veille réglementaire (RGPD, CCPA, AI Act), et le CoE suit les évolutions technologiques (catalogage, qualité, gouvernance de l'IA). Ils présentent leurs conclusions au comité chaque trimestre.